

09 Shoot Fish in a Barrel

Jonathan Knudsen

jonathan.knudsen@duke.edu

Fall 2019

The goal of this assignment is to use American Fuzzy Lop (AFL) to locate vulnerabilities in old software.

I recommend using your vcm.duke.edu virtual machine, but you are welcome to use whatever hardware you have available.

Give yourself plenty of time; you should really leave afl-fuzz running for a few hours at the very least.

Choose Your Target

Select one of the projects listed in AFL's **bug-o-rama trophy case** here:

<http://lcamtuf.coredump.cx/afl/>

You can choose whichever one you want except libtiff.

Choose carefully; you want something that's not huge and not too hard to work with. If you pick a target and are having trouble working with it, consider choosing another. The one I showed in class (libtiff) was pretty nice, because it was fairly simple to build, it built in about a minute, and it included a binary suitable for testing.

Travel to the Past

Get the source code, then retrieve an older version of the source code using git tags or some other mechanism. Some projects have archives of the source for past releases.

Make sure you can build the project.

Fuzz

Locate an appropriate binary that you can use to test the target code. For libtiff, the tiffdump binary was already made.

If a statically linked binary is available, use it. If you must use a dynamically linked binary, use ldd to verify that it links appropriately. (We covered this in the lecture, looking at tiffdump specifically.)

Now rebuild the project using the afl-gcc compiler (and if necessary, afl-g++).

Locate or create one or more input files.

Run afl-fuzz on your target. Let it go for a few hours at least; a full day would be even better. You will have to change the setting at vcm.duke.edu so that your VM does not get automatically shut off.

Once you have a decent set of results, reproduce at least one of the failures.

Submission

Your submission should include all the information I need to reproduce your results. At a minimum, include the following:

1. What is your target software and where did you get the source code?
2. How did you get an older version of the source code? Which version did you retrieve?
3. What steps did you follow to build your target software?
4. What steps did you follow to build your target software with the AFL instrumentation?
5. What did you use for AFL's input?
6. How long did you run AFL? How many crashes and hangs did you find?
7. Zip up your AFL output directory and submit it.